

COMPTE RENDU DU TP 4.1 : MISE EN PLACE D'UN PARE-FEU PFSense ET SEGMENTATION DU LABORATOIRE

1. Introduction et Contexte

Jusqu'à présent, l'environnement de laboratoire utilisait une architecture réseau plate où toutes les machines virtuelles (Kali Linux, Ubuntu, Windows) communiquaient librement sur un même réseau **Host-Only**. Cette configuration est risquée car elle permet une progression latérale facile pour un attaquant.

Objectif du TP : Transformer cette architecture en un réseau segmenté en introduisant un parefeu **pfSense**. Ce dernier servira de passerelle entre un réseau interne protégé (LAN) et un réseau externe (WAN).

2. Architecture Réseau

L'infrastructure a été segmentée en deux zones distinctes séparées par le pare-feu :

- **Zone WAN (Réseau Externe)**
- **Zone LAN (Réseau Interne)**

Configuration des interfaces pfSense :

Interface	Mode VMw	Rôle
Interface 1 (WAN)	NAT	Accès Internet et lien vers l'attaquant
Interface 2 (LAN)	Host-Only	Réseau privé des machines internes

3. Déploiement et Configuration

Installation de pfSense

La VM pfSense a été installée avec les paramètres recommandés (2 Go RAM, 2 cœurs CPU). Après l'attribution des interfaces (WAN sur la première carte, LAN sur la deuxième), l'adresse IP **192.168.1.1** a été définie comme passerelle du LAN.

```
FreeBSD/amd64 (pfSense.home.arp) (ttyv0)

VMware Virtual Machine - Netgate Device ID: 72c3892041930ecebcb3

*** Welcome to pfSense 2.6.0-RELEASE (amd64) on pfSense ***

WAN (wan)      -> em0      -> v4/DHCP4: 192.168.13.142/24
LAN (lan)      -> em1      -> v4: 192.168.1.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults  13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                 15) Restore recent configuration
7) Ping host                   16) Restart PHP-FPM
8) Shell

Enter an option:
Message from syslogd@pfSense at Apr 27 22:25:08 ...
php-fpm[192621]: /index.php: Successful login for user 'admin' from: 192.168.1.10
(Local Database)
```

Configuration des machines clientes

Pour intégrer le LAN, les interfaces réseau d'Ubuntu et Windows ont été basculées en **Host-Only** (liées au LAN de pfSense).

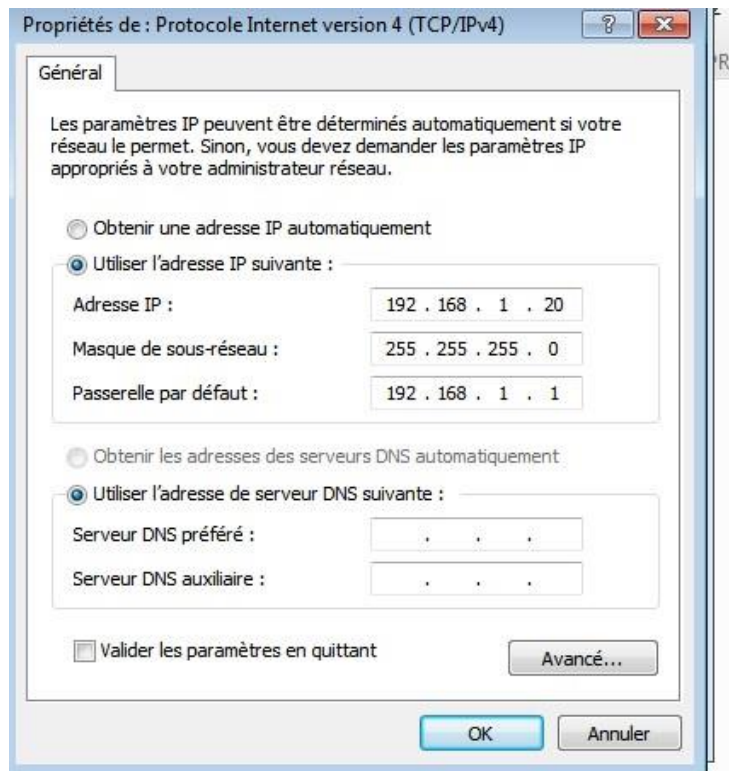
- **Sur Ubuntu :**

- IP : 192.168.1.10/24 ◦
- Passerelle : 192.168.1.1

```
nguilfofotso@nguilfofotso:~$ sudo ip addr add 192.168.1.10/24 dev ens37
nguilfofotso@nguilfofotso:~$ sudo ip route add default via 192.168.1.1
nguilfofotso@nguilfofotso:~$ ip a
```

- **Sur Windows :**

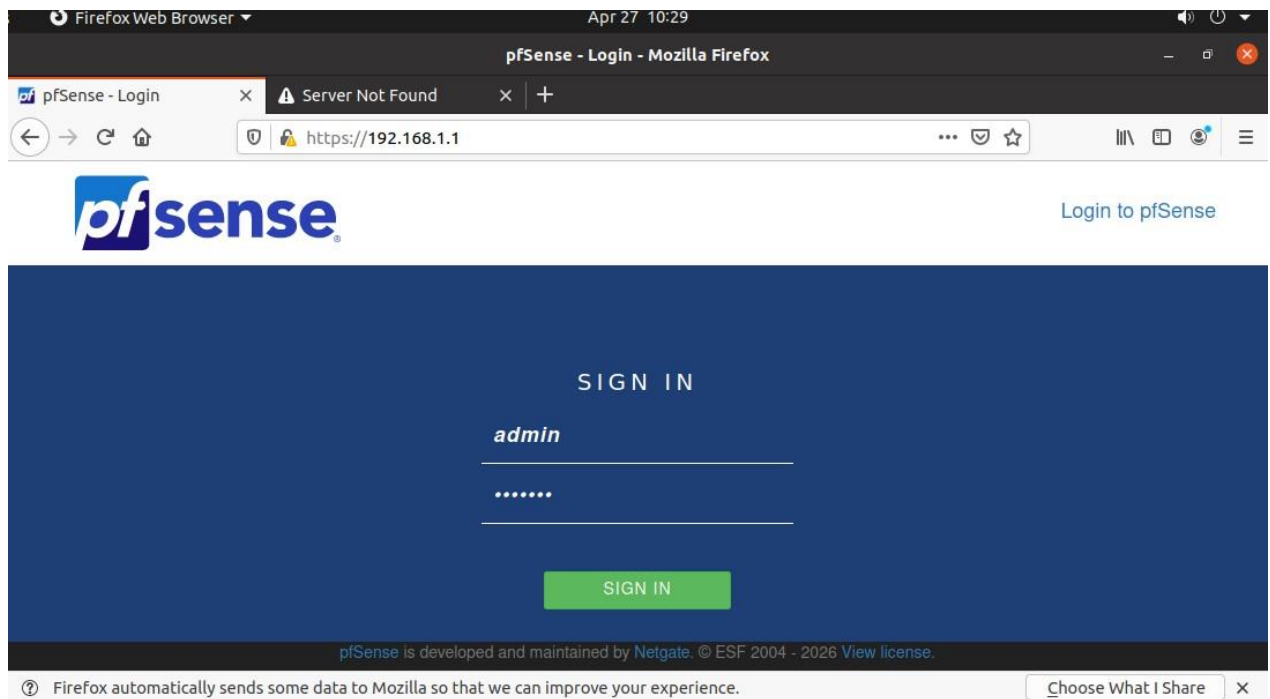
- IP : 192.168.1.20 ◦
- Masque : 255.255.255.0
- Passerelle : 192.168.1.1



Après avoir configuré les interfaces de nos machines clientes, nous allons ensuite accéder à l'interface de pfSense via le navigateur de la machine cliente Ubuntu. Pour cela, nous allons entrer : <https://192.168.1.1>.

Ensuite, entrer :

- Utilisateur : **admin** ;
- Mot de passe : **pfSense**.



4. Filtrage et Contrôle des Flux

Mise en place de la règle de sécurité

Par défaut, pfSense autorise tout le trafic sortant. Pour sécuriser le réseau, nous avons restreint les flux sur l'interface LAN :

Création d'une règle spécifique :

- **Action** : Pass ○ **Interface** : LAN ○
 Protocole : TCP
- **Port de destination** : 80 (HTTP)

https://192.168.1.1/firewall_rules_edit.php?if=lan&after=-1 60%

Edit Firewall Rule

Action Pass
 Choose what to do with packets that match the criteria specified below.
 Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled ☐ Disable this rule
 Set this option to disable this rule without removing it from the list.

Interface LAN
 Choose the interface from which packets must come to match this rule.

Address Family IPv4
 Select the Internet Protocol version this rule applies to.

Protocol TCP
 Choose which IP protocol this rule should match.

Source

Source ☐ Invert match any Source Address /
Display Advanced
 The **Source Port Range** for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.

Destination

Destination ☐ Invert match any Destination Address /

Destination Port Range HTTP (80) HTTP (80)
 From Custom To Custom

Tests de fonctionnement

- **curl http://example.com** (Accès Web) : Le port 80 est autorisé par la règle.
- **Ping 8.8.8.8** (Test de connectivité) : Le protocole ICMP n'est pas autorisé.

```
ngulfotats@ngulfotats:~$ curl http://example.com
<!doctype html><html lang="en"><head><title>Example Domain</title><meta name="viewport" content="width=device-width, initial-scale=1"><style>body{background-color:#f0f0f0;margin:10px auto;font-family:sans-serif}h1{font-size:1.5em}div{opacity:0.8}a:link,a:visited{color:#34811f}style=</head><body><div><h1>Example Domain</h1><p>This domain is for use in documentation examples without needing permission. Avoid use in operations.</p><p><a href="https://iana.org/domains/example">Learn more</a></p></div></body></html>
ngulfotats@ngulfotats:~$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data:
^C
--- 8.8.8.8 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3000ms
ngulfotats@ngulfotats:~$
```

- **Nmap -Ss 8.8.8.8** (Scan de ports) : Les communications non explicitement autorisées sont bloquées

```
ngulfofetso@ngulfofetso:~$ sudo nmap -sS 8.8.8.8
Starting Nmap 7.80 ( https://nmap.org ) at 2026-04-27 15:46 PDT
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.12 seconds
ngulfofetso@ngulfofetso:~$
```

5. Analyse et Interprétation

La règle mise en place est efficace car elle applique le principe du **moindre privilège**.

- **Ce qu'elle autorise** : Uniquement la navigation Web non sécurisée (port 80).
- **Ce qu'elle bloque** : Tout le reste (Ping, DNS, HTTPS, SSH, etc.).
- **Pourquoi elle fonctionne** : pfSense utilise un filtrage "Stateful". Si un paquet ne correspond pas à une règle "Pass" explicite, il est rejeté par la règle de nettoyage implicite (Deny All).

Cela empêche une machine compromise de communiquer avec un serveur de commande (C2) sur des ports non standards ou de réaliser des scans réseau vers l'extérieur.

6. Propositions d'améliorations

Pour renforcer davantage la sécurité de cette architecture, nous pourrions :

1. **Migrer vers le HTTPS** : Modifier la règle pour autoriser uniquement le port **443** et bloquer le port 80, afin de garantir le chiffrement des données.
2. **Mise en place d'une DMZ** : Créer une troisième zone isolée pour les serveurs devant être accessibles depuis l'extérieur (WAN), tout en les empêchant d'initier des connexions vers le LAN.
3. **Filtrage ICMP sélectif** : Autoriser le ping uniquement vers la passerelle pour le diagnostic, tout en le bloquant vers l'extérieur.

Conclusion

Ce TP a permis de démontrer que la sécurité périmétrique est la première ligne de défense. La segmentation réseau via Pfsense transforme un environnement vulnérable en un réseau contrôlé où chaque flux est scruté et validé.